

ENTERPRISE DATA SECURITY GOVERNANCE AND TECHNICAL CONTROLS IMPLEMENTATION

Northstar Retail Group

Data Security GRC Portfolio Case Study

Prepared by John Chidi Goodluck
Portfolio prototype | Simulated organisation | July 2026

Document Status and Disclosure

Field	Record
Organisation	Northstar Retail Group (simulated)
Project type	Portfolio prototype
Prepared by	John Chidi Goodluck
Scope status	Professional case-study version after Phases 1-4
Overall progress	75% - publication and final QA remain
Confidentiality	Public portfolio content after sanitisation

This project is not presented as work completed for a real client or production environment. It converts genuine technical implementation evidence into a mature data-security governance, risk, and compliance case study.

AI-Assisted Delivery

AI tools supported project planning, drafting, formatting, spreadsheet generation, code assistance, and quality review. The portfolio owner defined the professional objective, provided oversight, executed technical steps requiring direct account access, validated results, reviewed risk assumptions, and approved the artefacts.

Contents

1. 1. Executive Summary
2. 2. Organisation, Problem and Scope
3. 3. Governance Framework
4. 4. Data Environment and Security Architecture
5. 5. Risk Assessment
6. 6. Technical Implementation and Control Evidence
7. 7. Privacy, Retention and Access Governance
8. 8. Model Risk Governance
9. 9. Control Effectiveness and Residual Risk
10. 10. Management Recommendations
11. 11. Professional Lessons Learned
12. 12. Evidence Appendix

1. Executive Summary

Northstar Retail Group is a simulated mid-sized omnichannel retailer using cloud-based data and analytics services to process retail transactions, website events, analytical summaries, machine-learning outputs, MongoDB documents, and management dashboards.

The organisation's core challenge is not merely generating reports. It must ensure that information remains accurate, appropriately accessed, protected from disclosure, retained only as needed, and used responsibly across multiple technologies and trust boundaries.

The implementation processed 9,994 transaction records and 100 simulated website-event records using Spark, Parquet, R, Shiny, MongoDB Atlas, and a basic web query application. The GRC layer added 11 classified data assets, 12 assessed risks, 12 treatment actions, 20 controls, a role matrix, retention schedule, privacy assessment, model-risk record, and control-to-evidence mapping.

Outcome area	Result
Data integrity	Parsing failure identified, corrected, and validated with zero nulls in six critical fields.
Risk management	Twelve material risks assessed with accountable treatment owners and residual risk.
Access governance	Role-based access matrix and separation of data, platform, GRC, model, and business responsibilities.
Model governance	Performance metrics, limitations, prohibited uses, oversight, monitoring, and retirement triggers documented.
Evidence assurance	Twelve sanitised evidence cards created from genuine outputs; academic and account identifiers removed.
Management readiness	Prioritised recommendations for network restriction, least privilege, secure applications, retention, monitoring, and recovery.

2. Organisation, Problem and Scope

2.1 Simulated organisation

Northstar Retail Group operates retail and digital channels and uses analytics to understand sales, profitability, product performance, regional performance, website behaviour, and model results. The environment relies on cloud workspaces and managed database services.

2.2 Business problem

- Data enters through structured and semi-structured formats with different parsing requirements.
- A data-quality failure can corrupt analytical fields and undermine business decisions.
- Raw, cleaned, derived, and model data require different access and retention decisions.
- Credentials, public links, broad database access, and over-privileged identities can expose data.
- Dashboards can disclose sensitive commercial or behavioural information.
- A modest-performing model can be misused when its purpose and limitations are not governed.
- Cloud dependencies require resilience, monitoring, privacy, and third-party oversight.

2.3 Scope

In scope	Out of scope
Data acquisition, ingestion, quality, storage, analytics, model use, NoSQL serving, dashboards, access, privacy, retention, resilience, and incident readiness.	Production deployment, penetration testing, legal opinion, formal certification, live customer data, and guaranteed regulatory compliance.

2.4 Success criteria

- No school, assessment, matriculation, student-email, or lecturer references in public artefacts.
- No credentials, connection strings, personal account information, or temporary application URLs.
- Implemented controls are evidence-backed; recommendations are clearly labelled.
- The case study is understandable to technical, GRC, and recruitment audiences.
- The simulated organisation and AI-assisted delivery are disclosed.

3. Governance Framework

The governance approach integrates accountability, data ownership, risk treatment, lifecycle management, privacy, access, model oversight, and assurance evidence.

Principle	Application
Purpose limitation	Every data asset has a documented business purpose and approved use.
Data minimisation	Only necessary fields should be collected, stored, displayed, and retained.
Accountability	Assets, risks, controls, treatments, and models have assigned owners.
Least privilege	Human and service identities receive only the access required for their role.
Integrity by design	Schema validation, controlled parsing, and count reconciliation precede analytics.
Lifecycle security	Controls extend from source acquisition through disposal.
Evidence-based assurance	Public claims are linked to governance or technical evidence.
Human oversight	Model outputs support accountable decisions and do not replace review without approval.

3.1 Governance artefacts

- Data inventory and classification register
- Data-security risk register and treatment plan
- Control catalogue and control-to-evidence matrix
- Role-based access matrix and governance RACI
- Retention and secure-disposal schedule
- Privacy assessment
- Model-risk governance record
- Technical evidence register and sanitisation manifest

4. Data Environment and Security Architecture

The architecture connects data sources, ingestion, storage, Spark processing, analytics and machine learning, MongoDB serving, and dashboard-based decision support. Security and governance are cross-cutting rather than isolated in a single layer.

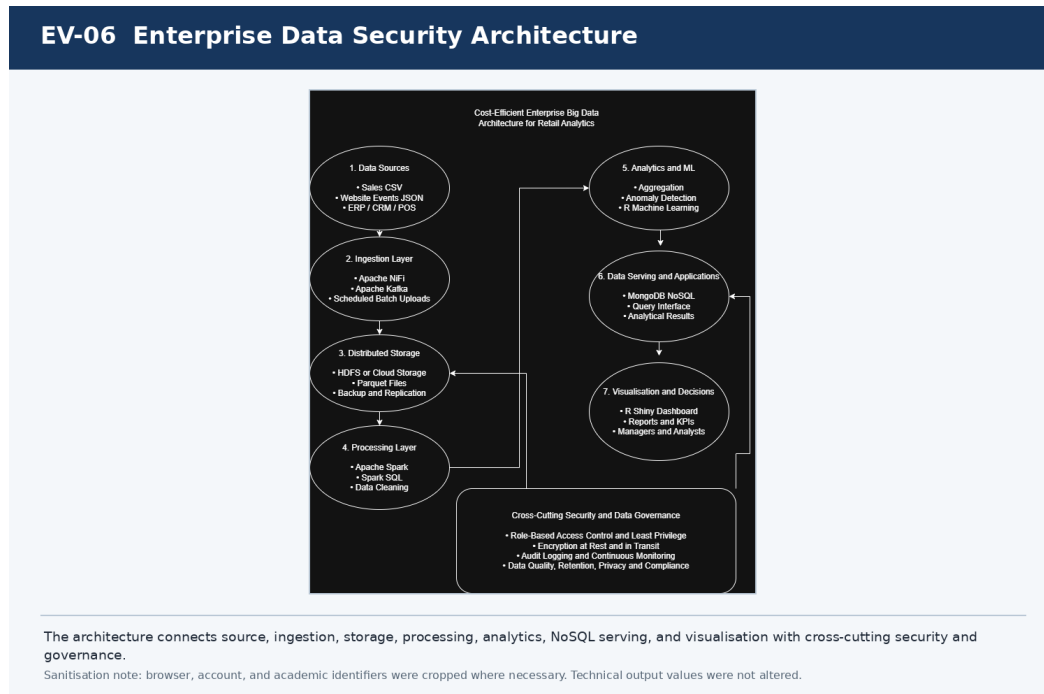


Figure 1. Seven-layer analytics architecture with cross-cutting access, encryption, monitoring, data quality, retention, privacy, and compliance controls.

4.1 Trust boundaries

- Operational or external data sources to ingestion
- Ingestion services to controlled storage
- Storage to Spark processing
- Processing to modelling environments
- Analytical outputs to MongoDB
- MongoDB to query applications
- Applications to end users
- Third-party cloud services to organisational governance

4.2 Production security priorities

- Private or tightly restricted database connectivity
- Central identity and role enforcement
- Managed secret and key management
- Authenticated, role-aware dashboards
- Centralised logs and alerting
- Tested backup and recovery objectives
- Approved retention automation
- Formal third-party assurance

5. Risk Assessment

Twelve material risks were assessed. The prototype had high inherent exposure because data crossed multiple services and the environment initially relied on temporary, broad connectivity and public application mechanisms.

ID	Risk	Inherent	Residual	Status
R-001	Untrusted or malformed source data	12 - High	6 - Medium	In progress
R-002	CSV parsing corrupts analytical fields	16 - High	4 - Low	Implemented
R-003	Unauthorised storage access	15 - High	8 - Medium	In progress
R-004	Credential or connection-string disclosure	15 - High	4 - Low	Implemented
R-005	Broad database network exposure	20 - Critical	4 - Low	Closed
R-006	Sensitive dashboard or application disclosure	12 - High	6 - Medium	In progress
R-007	Excessive database privileges	15 - High	8 - Medium	In progress
R-008	Model misuse and inaccurate decisions	16 - High	6 - Medium	Monitoring
R-009	Excessive retention and incomplete deletion	12 - High	4 - Low	In progress
R-010	Insufficient logging and delayed detection	12 - High	6 - Medium	Recommended
R-011	Data or service loss	12 - High	6 - Medium	Recommended
R-012	Behavioural-data privacy and re-identification	12 - High	6 - Medium	In progress

The largest immediate risk was temporary broad database network exposure. It was treated by removing the allow-from-anywhere rule after the prototype. Production architecture should use private endpoints or controlled application hosts.

6. Technical Implementation and Control Evidence

6.1 Data acquisition and integrity

Structured retail data and semi-structured website events were ingested into Spark. Initial type inference stored several analytical fields as strings. A quotation-related parsing problem shifted a product description into a numerical field. Explicit quote, escape, and multiline settings corrected the issue.

EV-01 Data Quality Validation

```

    "profit"
  ]
}
)

print("Null values after corrected type conversion:")
conversion_check_df.show(truncate=False)

... Null values after corrected type conversion:
+-----+-----+-----+-----+-----+-----+
|order_date|ship_date|sales|quantity|discount|profit|
+-----+-----+-----+-----+-----+-----+
|to       |to       |to    |to       |to       |to     |

```

Corrected date and numeric fields were checked for nulls after controlled CSV parsing. All six critical fields returned zero null values.

Sanitisation note: browser, account, and academic identifiers were cropped where necessary. Technical output values were not altered.

Figure 2. Post-conversion validation demonstrating controlled data-type correction and null checking.

6.2 Profiling and anomaly detection

Metric	Result
Transaction rows	9,994
Website-event rows	100
Average sales	229.86
Maximum sales	22,638.48
Maximum discount	80%
Minimum profit	-6,599.98
Loss-making rows	1,871 (18.72%)
High-discount rows	922 at 50% or above

EV-03 Loss and Anomaly Detection

```

)

print("Ten largest loss-making records:")
largest_losses_df.show(10, truncate=False)

Ten largest loss-making records:
+-----+-----+-----+-----+-----+-----+
|order_id|product_name|category|sales|discount|profit|
+-----+-----+-----+-----+-----+-----+
|CA-2016-108196|Cubify CubeX 3D Printer Double Head Print|Technology|4499.985|0.7|-6599.978|
|US-2017-168116|Cubify CubeX 3D Printer Triple Head Print|Technology|7999.98|0.5|-3839.9904|
|CA-2014-169019|GBC DocuBind P400 Electric Binding System|Office Supplies|2177.584|0.8|-3701.8928|
|CA-2017-134845|Lexmark MX611dhe Monochrome Laser Printer|Technology|2549.985|0.7|-3399.98|

```

The implementation identified 1,871 loss-making rows (18.72%) and ranked the most severe losses for investigation.

Sanitisation note: browser, account, and academic identifiers were cropped where necessary. Technical output values were not altered.

Figure 3. Loss-ranking evidence used to support integrity monitoring and management investigation.

6.3 Governed analytics and performance

Technology produced the strongest category sales and profit. Furniture generated strong sales but weak profit. The West was the strongest region. The analysis also showed that high sales did not guarantee positive profit.

Category	Sales	Profit	Quantity	Unique orders
Technology	836,154.03	145,454.95	6,939	1,544
Furniture	741,999.80	18,451.27	8,028	1,764
Office Supplies	719,047.03	122,490.80	22,906	3,742

EV-05 Spark Processing Performance Test

```
print(
    "\nNote: results may vary because this dataset is small "
    "and the test runs in a local Colab environment."
)

*** Spark performance demonstration
-----
Uncached aggregation time: 0.3358 seconds
Cached aggregation time: 0.2074 seconds
The cached in-memory operation completed faster.
```

A local prototype test compared uncached and cached aggregation. Cached processing completed faster in this run; the result is not represented as an enterprise benchmark.

Sanitisation note: browser, account, and academic identifiers were cropped where necessary. Technical output values were not altered.

Figure 4. Local cached-versus-uncached Spark aggregation test, presented with an explicit prototype limitation.

6.4 NoSQL serving and application controls

MongoDB Atlas stored 12 analytical documents: three category records, four regional records, and five top-product records. The web interface used predefined record types and a numeric threshold to query the database and display live filtered results.

EV-12 Data Governance Query Application

Query analytical results stored in MongoDB Atlas.

Select Record Type

Minimum Total Sales

Regional Performance

500000

Query MongoDB

3 record(s) returned from MongoDB Atlas.

Database Results

record_type	name	total_sales	total_profit	unique
regional_performance	West	725457.82	108418.45	1611
regional_performance	East	678781.24	91522.78	1401
regional_performance	Central	501239.89	39706.36	1175

The web interface sent a filtered request to MongoDB Atlas and returned three matching regional records. Academic and browser identifiers were cropped; execution content is unchanged.

Sanitisation note: browser, account, and academic identifiers were cropped where necessary. Technical output values were not altered.

Figure 5. Sanitised query-application evidence showing controlled filters and live MongoDB results.

6.5 Control mapping conclusion

Status	Interpretation
Implemented	Directly demonstrated and supported by technical or governance evidence.
Partially implemented	A meaningful prototype control exists, but production enforcement or testing remains.
Recommended	Required for mature deployment but not implemented in the prototype.

7. Privacy, Retention and Access Governance

7.1 Data classification

Asset group	Classification	Primary concern
Retail transactions and cleaned datasets	Confidential	Customer, commercial, and data-integrity exposure
Website behavioural events	Confidential	Tracking, linkage, and re-identification
Analytical summaries and model outputs	Internal	Commercial sensitivity and misinterpretation
MongoDB analytical records	Confidential	Credential, privilege, and network exposure
Credentials and secrets	Restricted	Account takeover and unauthorised database access
Logs and evidence	Confidential	Secrets, personal details, or misleading public evidence

7.2 Access governance

The access matrix separates Data Owner, Data Engineer, Data Analyst, Database Administrator, GRC/Security, Privacy, Model Owner, Business Manager, Internal Auditor, and application-service responsibilities.

- Owners approve purpose, classification, retention, and material access.
- Engineers maintain ingestion, quality, lineage, and controlled transformations.
- Database and platform administrators manage infrastructure but should not approve their own access.
- Analysts receive approved analytical access rather than unrestricted administrative access.
- GRC and audit roles review logs, configurations, risks, and evidence without receiving secret values.
- Service identities receive only the permissions required for application functions.

7.3 Retention and disposal

Asset	Illustrative retention	Disposal expectation
Retail transactions	7 years	Verified deletion after legal, finance, and hold requirements are satisfied.
Website events	12 months	Delete identifiers and event records; aggregate or anonymise only when approved.
Cleaned analytical data	24 months	Delete active, temporary, and backup copies according to lifecycle controls.
Model training data	Model life + 12 months	Retain approved version for reproducibility, then securely dispose.
Predictions and metrics	12 months	Remove obsolete row-level predictions and retain approved validation records.
Credentials	Until rotated or revoked	Revoke and delete obsolete values; never retain usable secrets in evidence.

7.4 Privacy conclusion

Behavioural and transaction data can become personal or sensitive when linked to identities or other datasets. A mature deployment requires purpose limitation, minimisation, transparency, approved retention, secure deletion, controlled linkage, individual-rights handling where applicable, and formal third-party review.

8. Model Risk Governance

Field	Governance record
Model	Retail Profit Prediction Prototype
Method	Multiple linear regression
Target	Profit
Predictors	Sales, Quantity, Discount, Category, Segment, Region
Training / testing	7,995 / 1,999 rows
Metrics	MAE 57.49; RMSE 223.13; test R-squared 0.4270
Approved use	Exploratory decision support and governance demonstration
Prohibited use	Sole basis for pricing, discounts, eligibility, employee action, or other material automated decisions
Residual risk	Medium for portfolio demonstration; High for ungoverned production automation

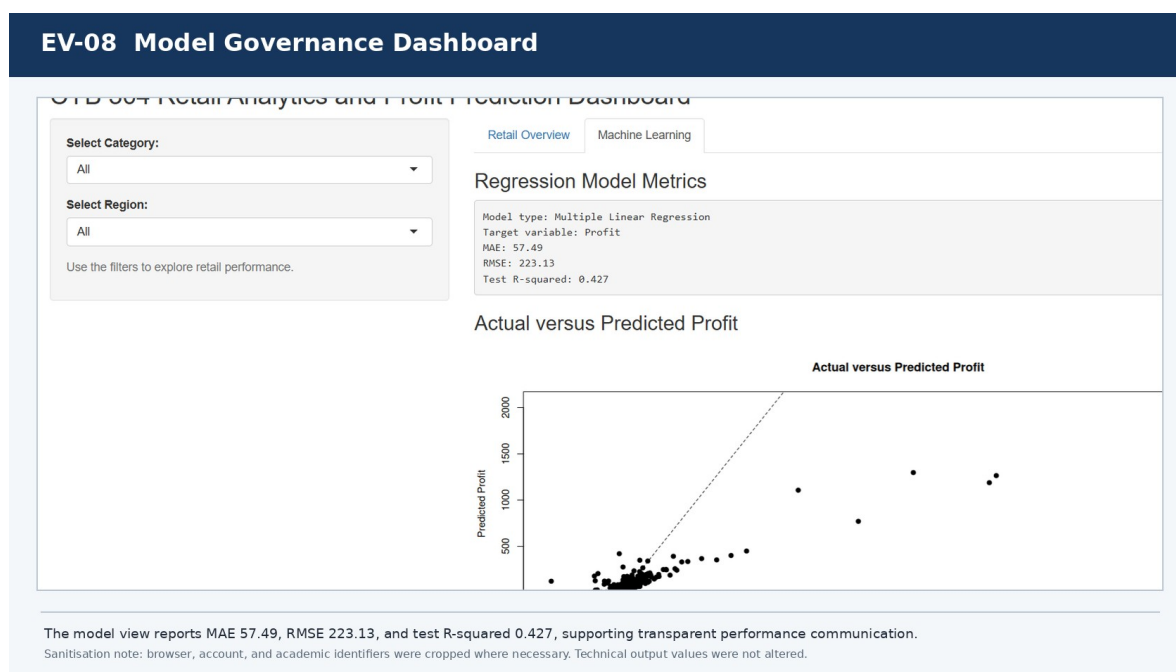


Figure 6. Model metrics displayed with sufficient transparency to support governance review and limitation disclosure.

8.1 Required production governance

1. Independent data and model validation
2. Version-controlled training data and code
3. Cross-validation and alternative-model comparison
4. Bias and error analysis across relevant groups
5. Performance and data-drift monitoring

6. Human review of material decisions

7. Change-control, override, incident, and retirement records

9. Control Effectiveness and Residual Risk

Control area	Conclusion	Remaining gap
Data integrity	Implemented	Automate provenance, checksums, rejected-record handling, and batch reconciliation.
Secret management	Implemented	Add automated repository secret scanning and formal rotation evidence.
TLS	Implemented	Retain production certificate and configuration assurance.
Role-based access	Partially implemented	Enforce roles in platforms and complete periodic access reviews.
Network restriction	Partially implemented	Adopt private endpoints or tightly controlled hosts.
Dashboard security	Partially implemented	Add authentication, field-level restrictions, and secure export controls.
Retention	Partially implemented	Approve periods and automate disposal evidence.
Monitoring	Recommended	Centralise logs, alerts, review, and retention.
Recovery	Recommended	Define and test RTO, RPO, backups, and restoration.
Incident response	Recommended	Create and exercise a data-security incident playbook.

Overall residual risk is Medium. The prototype demonstrates credible control design and implementation evidence, but production maturity depends on authenticated applications, enforced roles, restricted networks, monitoring, recovery testing, approved retention, vendor assurance, and independent model validation.

10. Management Recommendations

Priority	Recommendation
Critical	Restrict production database connectivity to approved networks, hosts, or private endpoints.
High	Enforce least-privilege roles and quarterly access reviews for users and service identities.
High	Automate source approval, checksums, schema validation, rejected-record handling, and count reconciliation.
High	Deploy authenticated, role-aware dashboards with field minimisation and secure export controls.
High	Approve model-use, independent validation, monitoring, human oversight, and retirement requirements.
High	Operationalise approved retention and secure-disposal workflows with evidence of deletion.
Medium	Centralise database, application, and processing logs with security alerting.
Medium	Define RTO and RPO and test restoration of data, code, configurations, and secrets.

Priority	Recommendation
Medium	Complete third-party risk reviews for managed cloud and analytics platforms.
Medium	Develop and exercise a data-security incident-response playbook.

11. Professional Lessons Learned

- Data integrity is a governance issue: a parsing error can directly compromise reporting, risk assessment, and management decisions.
- Technical controls become stronger portfolio evidence when each one is linked to a risk, owner, control objective, test result, and residual gap.
- Model metrics are not a claim of production readiness. Transparent limitations and human oversight are part of responsible model governance.
- A public portfolio requires its own security review. Screenshots, repository history, temporary URLs, account details, and secret exposure must be treated as risks.
- A mature GRC implementation distinguishes between controls demonstrated in the prototype and controls merely recommended for production.
- Security, privacy, resilience, retention, access, and model governance must operate across the complete data lifecycle.

11.1 Portfolio positioning

Designed and implemented a security-governed enterprise analytics prototype for a simulated retail organisation. The work integrated data classification, lifecycle risk assessment, access governance, secure credential handling, data-quality controls, privacy considerations, model oversight, NoSQL serving, dashboards, and evidence-based control mapping across Spark, R, MongoDB, and cloud workspaces.

12. Evidence Appendix

The following figures are sanitised extracts from genuine implementation evidence. Browser, account, academic, and temporary-link information was cropped where necessary. Technical outputs and values were not altered.

EV-02 Data Profiling and Outlier Awareness

```

    "50%",
    "75%",
    "max"
  ).show(truncate=False)

```

	sales	quantity	discount	profit
count	9994	9994	9994	9994
mean	1229.8580008304938	3.789573744246548	0.15620272163298934	28.656896307784802
stddev	623.2451005086809	2.225109691141402	0.20645196782571626	234.2601076909573
min	0.444	1	0.0	-6590.978
25%	17.248	2	0.0	1.728
50%	54.384	3	0.2	8.6436

Spark profiling covered 9,994 records and exposed skewed sales values, severe loss outliers, and a maximum discount of 80%.

Sanitisation note: browser, account, and academic identifiers were cropped where necessary. Technical output values were not altered.

Figure A1. Spark data profiling and statistical summary.

EV-04 Governed Analytical Output

```

    .orderBy(col("total_sales").desc())
  )

  print("Category performance:")
  category_performance_df.show(truncate=False)

```

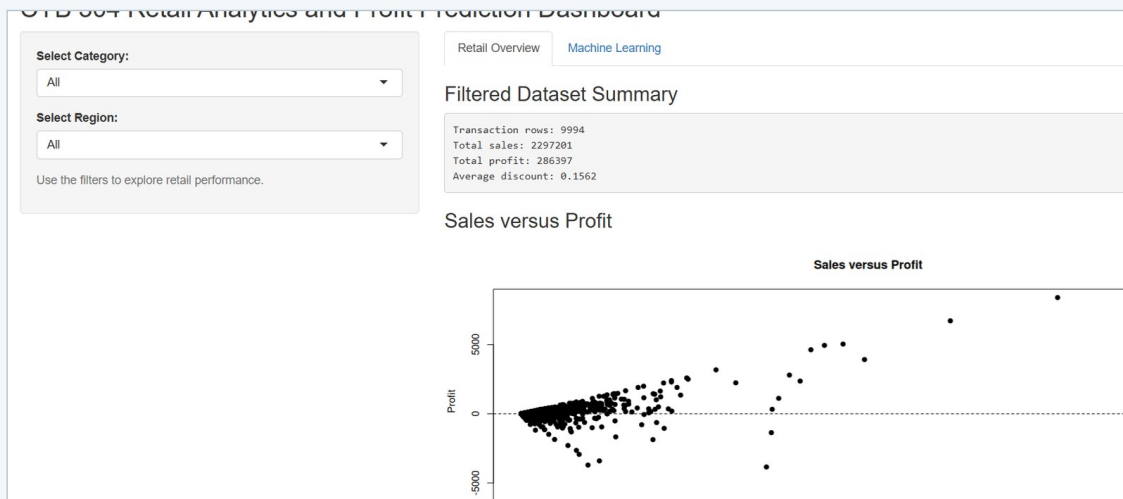
category	total_sales	total_profit	total_quantity	unique_orders
Technology	836154.03	145454.95	6939	1544
Competition	743000.0	110451.37	10000	13764

Category-level aggregation produced traceable sales, profit, quantity, and unique-order metrics for management reporting.

Sanitisation note: browser, account, and academic identifiers were cropped where necessary. Technical output values were not altered.

Figure A2. Category-level analytical aggregation.

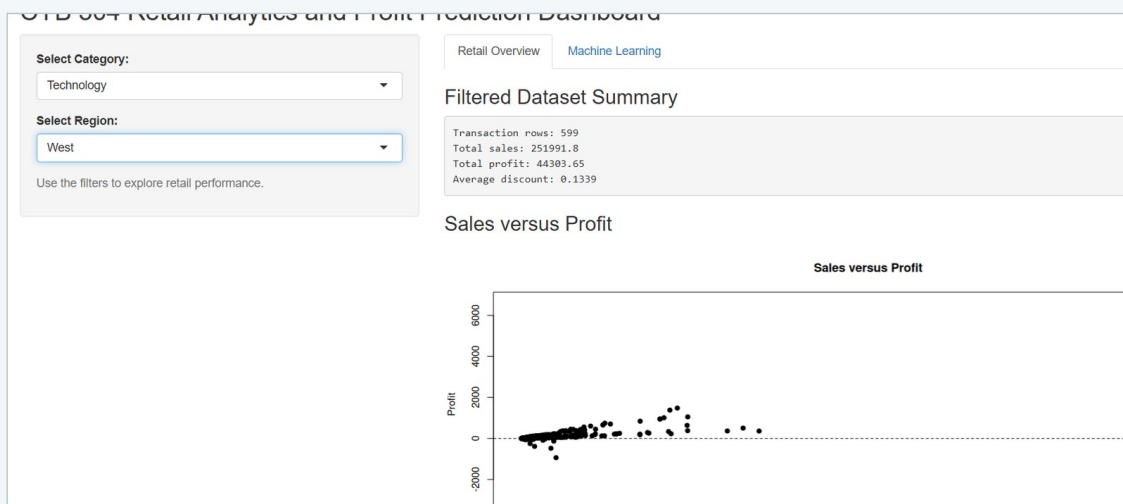
EV-07 Retail Analytics Dashboard



The dashboard presents filtered transaction metrics and sales-versus-profit analysis for authorised decision support.
 Sanitisation note: browser, account, and academic identifiers were cropped where necessary. Technical output values were not altered.

Figure A3. Retail analytics dashboard view.

EV-09 Dashboard Filter Validation



Technology and West filters returned 599 transactions, sales of 251,991.80, profit of 44,303.65, and average discount of 0.1339.
 Sanitisation note: browser, account, and academic identifiers were cropped where necessary. Technical output values were not altered.

Figure A4. Technology and West dashboard filter validation.

EV-10 NoSQL Document Insertion

```
collection.delete_many({})

insert_result = collection.insert_many(
    analytical_documents
)

print("Analytical documents inserted successfully.")
print("Documents inserted:", len(insert_result.inserted_ids))
print("Documents currently in collection:", collection.count_documents({}))

*** Analytical documents inserted successfully.
```

Twelve analytical documents were inserted successfully and the collection count confirmed all records were present.
Sanitisation note: browser, account, and academic identifiers were cropped where necessary. Technical output values were not altered.

Figure A5. MongoDB analytical-document insertion result.

EV-11 Filtered NoSQL Query

```
{
  'total_quantity': 22906,
  'total_sales': 741999.8,
  'unique_orders': 1764
}

*** {
  'name': 'Office Supplies',
  'total_profit': 122490.8,
  'total_quantity': 22906,
  'total_sales': 719047.03,
  'unique_orders': 3742
}

REGIONS WITH SALES ABOVE 500,000
-----
{
  'name': 'West',
  'total_profit': 108418.45,
  'total_sales': 725457.82,
  'unique_orders': 1611
}
{
  'name': 'East',
  'total_profit': 91522.78,
  'total_sales': 678781.24,
  'unique_orders': 1401
}
{
  'name': 'Central',
  'total_profit': 39706.36,
  'total_sales': 501239.89,
```

A regional query returned West, East, and Central for total sales above 500,000, demonstrating filtering, projection, and sorting.
Sanitisation note: browser, account, and academic identifiers were cropped where necessary. Technical output values were not altered.

Figure A6. Filtered regional NoSQL query result.

Appendix conclusion

The evidence set supports the portfolio claims for data-quality validation, analytical processing, anomaly detection, dashboard filtering, model-metric transparency, NoSQL insertion, database querying, and basic web application controls.